ISO/IEC 27001:2022 – Information Security Risk Assessment

BLITZX Engineering | Portfolio Case Study | Clauses 6.1.2 and 8.2

Document ID	BLX-GRC-RA-001
Version	1.0 – Draft
Status	Proposed learning assessment; not formally approved
Basis	BLITZX Engineering case study and supplied Risk Assessment Procedure
Prepared	6 November 2026

1. Purpose and scope

This focused assessment covers the three assets specified in the assignment: the primary data centre in Germany, SAP S/4HANA, and intellectual property relating to heavy machinery design and manufacturing. It applies the supplied Risk Assessment Procedure and aligns with ISO/IEC 27001:2022 clauses 6.1.2 and 8.2. It is not a complete enterprise-wide risk assessment.

2. Assessment method and scoring

Risk Score = Impact × Likelihood. Impact and likelihood use the supplied template's 1–5 scales.

R-01 – Primary data centre – Germany

Threat	Fire or environmental incident
Potential vulnerability	Potentially inadequate fire detection/suppression, environmental monitoring, power resilience, or physical safeguards. Not confirmed in the case study.
Risk event	Incident damages or disables the primary data centre, interrupting systems and business processes hosted there.
Potential impact	Significant disruption to dependent operations, recovery costs, and possible data availability/integrity impacts.
Existing controls / case-study evidence	The profile identifies a US secondary data centre but does not confirm fire protection, backup, replication, failover, or recovery-test effectiveness.
Proposed risk owner	IT Infrastructure / Data Centre Manager (proposed)
Impact	4 – Significant
Likelihood	2 – Rare
Risk score	4 × 2 = 8
Risk category	High
Evaluation decision	Treatment required
Recommended treatment	Verify fire detection and suppression, environmental monitoring, UPS/generator resilience, physical access, backup integrity, secondary-site failover, and disaster-recovery test evidence.

R-02 – SAP S/4HANA ERP

Threat	Attacker uses compromised credentials to gain unauthorized access
Potential vulnerability	Potentially weak MFA coverage, excessive privileges, weak privileged-account governance, or insufficient monitoring. Not confirmed in the case study.
Risk event	Unauthorized access to or alteration of SAP data and transactions through a compromised user or privileged account.

Potential impact	Disclosure or modification of financial, HR, supply-chain, and project data; fraudulent transactions; disruption to procurement, finance, payroll, or operations.
Existing controls / case-study evidence	The profile confirms SAP supports finance, supply chain, HR, and project management, with German primary and US secondary data centres. It does not specify MFA, role design, privileged access, logging, or access reviews.
Proposed risk owner	SAP Application Owner / IT Security Manager (proposed)
Impact	4 – Significant
Likelihood	3 – Unlikely
Risk score	4 × 3 = 12
Risk category	High
Evaluation decision	Treatment required
Recommended treatment	Review least-privilege roles, enforce MFA, govern privileged accounts, review segregation of duties, recertify access, monitor audit logs, and test ERP incident response.

R-03 – Intellectual property – heavy machinery design and manufacturing

Threat	Industrial espionage, cyber theft, or malicious/compromised insider
Potential vulnerability	Potentially broad access to engineering files, weak export/download controls, inadequate repository protection, or insufficient monitoring. Not confirmed in the case study.
Risk event	Unauthorized party accesses, copies, or exfiltrates designs, technical drawings, specifications, or manufacturing know-how, potentially through Siemens Teamcenter.
Potential impact	Loss of competitive advantage, product imitation, financial and contractual loss, reputational damage, and potential safety/quality implications if designs are altered.
Existing controls / case-study evidence	The profile identifies Siemens Teamcenter for product lifecycle and engineering, hosted on-premises with a German primary data centre. It does not specify access restrictions, encryption, DLP, logging, or supplier controls.
Proposed risk owner	Engineering / R&D Director and PLM System Owner (proposed)
Impact	5 – Extreme
Likelihood	4 – Likely
Risk score	5 × 4 = 20
Risk category	Very High
Evaluation decision	Immediate treatment required
Recommended treatment	Classify design data as highly confidential; restrict project/role access; review employee, contractor and supplier access; use MFA; protect data at rest/in transit; monitor bulk exports; implement suitable DLP and controlled export processes.

Risk acceptance criteria from the supplied template: Low 1–3 and Medium 4–6 are accepted and monitored; High 8–12 requires treatment; Very High 19–25 requires immediate treatment. The template does not define scores 7 and 13–18; clarify these gaps before formal adoption.

4. Risk prioritisation

1. R-03 – Intellectual property: 20 (Very High), immediate treatment. 2. R-02 – SAP S/4HANA: 12 (High), treatment required. 3. R-01 – German primary data centre: 8 (High), treatment required.

5. Conclusion

All three assessed risks exceed the template's Low and Medium acceptance bands. R-03 is Very High and should receive immediate treatment. R-02 and R-01 are High and also require treatment. These are initial estimates based on plausible scenarios and incomplete control information. Confirm existing controls, reassess residual risk, assign treatment owners and deadlines, and obtain formal approval for any residual-risk acceptance.

6. Assumptions and validation actions

• MCAS Engineering Group is treated as BLITZX Engineering for this exercise, as confirmed by the user.

• The profile does not describe detailed physical safeguards, backup/failover tests, SAP access controls, or Teamcenter data-protection controls.

• Threats and vulnerabilities are scenarios, not verified findings. Proposed owners and scores require validation with business and IT owners.

• Clarify acceptance-score gaps 7 and 13–18, validate the matrix, record actual controls, and approve the procedure before operational use.

• Reference basis: supplied Risk Assessment Procedure template; ISO/IEC 27001:2022 clauses 6.1.2 and 8.2. The numerical scales and acceptance bands are from the supplied template, not mandated by ISO 27001.